

Politique de Gestion des Correctifs Logiciels — Environnement Backend

Ce document décrit le processus défini et reproductible de BantuDelice pour identifier, prioriser (par gravité CVSS) et appliquer régulièrement les correctifs de sécurité sur les logiciels tiers gérant les données de la plateforme.

1. PROCESSUS DÉFINI ET REPRODUCTIBLE D'IDENTIFICATION DES CORRECTIFS

★ CONDITION 1 REQUISE — PROCESSUS D'IDENTIFICATION — SURLIGNÉ

BantuDelice maintient un processus défini, documenté et reproductible pour identifier les correctifs de sécurité dans les logiciels tiers de l'environnement backend, exécuté selon un calendrier mensuel et à chaque déploiement.

1.1 Sources de surveillance des vulnérabilités

Couche logicielle	Outil d'identification	Fréquence
Dépendances PHP / Laravel	<code>composer audit</code> — interroge la base packagist.org/advisories	Mensuelle + à chaque déploiement
Paquets système Ubuntu (apt)	<code>apt list --upgradable</code> + <code>unattended-upgrades</code>	Quotidienne (cron automatique)
PHP, Nginx, MySQL	Abonnement aux bulletins Ubuntu Security Notices (USN)	Continue (email)
CVE générales	NVD NIST — nvd.nist.gov (consultation manuelle)	Mensuelle

1.2 Processus reproductible — Étapes mensuelles



2. PRIORISATION DES CORRECTIFS PAR NIVEAU DE RISQUE CVSS

★ CONDITION 2 REQUISE — PRIORISATION PAR GRAVITÉ CVSS — SURLIGNÉ

Chaque vulnérabilité identifiée est classifiée selon son score CVSS v3.1 et priorisée selon les délais de correction suivants, appliqués sans exception :

- Critique (CVSS 9.0–10.0) — Correction sous 72 heures
- Élevée (CVSS 7.0–8.9) — Correction sous 7 jours
- Moyenne (CVSS 4.0–6.9) — Correction sous 30 jours
- Faible (CVSS 0.1–3.9) — Correction sous 90 jours

Niveau CVSS	Score	Délai de correction	Procédure
Critique	9.0 – 10.0	72 heures	Correction d'urgence — déploiement immédiat, notification direction
Élevée	7.0 – 8.9	7 jours	Correctif prioritaire au prochain cycle de déploiement planifié
Moyenne	4.0 – 6.9	30 jours	Inclus dans la mise à jour mensuelle standard
Faible	0.1 – 3.9	90 jours	Inclus dans la prochaine mise à jour trimestrielle

3. APPLICATION RÉGULIÈRE DES CORRECTIFS — OPÉRATIONS COURANTES

★ CONDITION 3 REQUISE — APPLICATION RÉGULIÈRE EN OPÉRATIONS COURANTES — SURLIGNÉ

Les correctifs de sécurité sont appliqués régulièrement dans le cadre des opérations courantes de BantuDelice, selon un calendrier défini :

- Dépendances PHP (composer) : mise à jour mensuelle le 1er de chaque mois + à chaque déploiement
- Système Ubuntu (apt) : mises à jour de sécurité automatiques quotidiennes via `unattended-upgrades`
- PHP / Nginx / MySQL : mise à jour manuelle mensuelle ou en urgence si CVE critique

3.1 Configuration des mises à jour automatiques système

```
# /etc/apt/apt.conf.d/50unattended-upgrades (VPS OVH)
Unattended-Upgrade::Allowed-Origins {
    "${distro_id}:${distro_codename}-security"; // ★ Mises à jour sécurité Ubuntu auto
};
Unattended-Upgrade::AutoFixInterruptedDpkg "true";
Unattended-Upgrade::MinimalSteps "true";
Unattended-Upgrade::Mail "gess198@gmail.com"; // Notification email
```

3.2 Preuve d'application — Audit du 3 juin 2026

Résultat composer audit — AVANT mise à jour (3 juin 2026, 21h00)

```
$ composer audit
Found 10 security vulnerability advisories affecting 7 packages:
phpseclib/phpseclib  high  CVE-2026-44167  OID amplification DoS
symfony/mime         high  CVE-2026-45067  SMTP CRLF injection
symfony/mailer       medium CVE-2026-45068  Argument injection sendmail
symfony/mime         medium CVE-2026-45070  Email header injection
symfony/routing      medium CVE-2026-45065  Route requirement bypass
symfony/http-foundation CVE-2026-48736  IPv6 PRIVATE_SUBNETS
symfony/routing      CVE-2026-48784  URL dot-segment encoding
phpseclib/phpseclib  low   CVE-2026-40194  Variable-time HMAC
symfony/polyfill-intl-idn low   CVE-2026-46644  Punycode xn-- labels
laravel/framework    CVE-2026-48019  CRLF injection email rule
```

Résultat composer audit — APRÈS mise à jour (3 juin 2026, 21h15)

```
$ composer update --no-dev && composer audit
9 packages updated successfully
Found 1 security vulnerability advisory affecting 1 package:
laravel/framework (no CVSS) CVE-2026-48019  CRLF injection email rule
→ Aucun patch disponible sur Laravel 10.x à ce jour
→ Mitigation appliquée : validation stricte des adresses email (voir section 4)
```

3.3 Calendrier de mise à jour

Tâche	Fréquence	Responsable	Dernier exécuté
<code>composer audit</code> + mise à jour	Mensuelle (1er du mois) + déploiements	Équipe technique	✓ 3 juin 2026
<code>apt upgrade</code> paquets sécurité	Quotidienne (automatique)	<code>unattended-upgrades</code>	✓ Actif en production
Mise à jour PHP / Nginx / MySQL	Mensuelle ou urgence	Équipe technique	PHP 8.3.6 — mai 2026

4. VULNÉRABILITÉ RESTANTE — PLAN DE MITIGATION

CVE	Package	Gravité	Statut	Mitigation
CVE-2026-48019	laravel/framework	Non classifiée	Aucun patch 10.x	Validation stricte des adresses email via <code>filter_var(FILTER_VALIDATE_EMAIL)</code> avant tout traitement. Migration vers Laravel 11 planifiée Q3 2026.

Cette vulnérabilité ne présente pas de risque d'accès non autorisé aux données de la plateforme Meta (CRLF injection sur règle email interne, pas d'exposition de données utilisateur).

